

O'REILLY®

Second
Edition

Zero Trust Networks

Building Secure Systems in Untrusted Networks



Razi Rais, Christina Morillo,
Evan Gilman & Doug Barth

Zero Trust Networks

This practical book provides a detailed explanation of the zero trust security model. Zero trust is a security paradigm shift that eliminates the concept of traditional perimeter-based security and requires you to “always assume breach” and “never trust but always verify.” The updated edition offers more scenarios, real-world examples, and in-depth explanations of key concepts to help you fully comprehend the zero trust security architecture.

- Examine fundamental concepts of zero trust security model, including trust engine, policy engine, and context aware agents
- Understand how this model embeds security within the system's operation, with guided scenarios at the end of each chapter
- Migrate from a perimeter-based network to a zero trust network in production
- Explore case studies that provide insights into organizations' zero trust journeys
- Learn about the various zero trust architectures, standards, and frameworks developed by NIST, CISA, DoD, and others

Razi Rais is a cybersecurity expert at Microsoft with over two decades of experience in building products.

Christina Morillo is an enterprise cybersecurity and technology leader with over two decades of experience.

Evan Gilman has built and operated systems in hostile environments throughout his career.

Doug Barth is a software engineer who loves to learn and share his knowledge with others.

“Zero trust is not just a strategy; it is a mindset that challenges assumptions, scrutinizes every interaction, and guards our digital systems against unseen foes. This book offers practical guidance for chief technology officers, engineers, and information technology professionals embarking on their zero trust journey.”

—Ann Johnson
Corporate Vice President,
Microsoft Security

“This book packages essential concepts of zero trust security in an easy to understand language. A definitive read for beginners and professionals alike.”

—Karan Dwivedi
Security Engineering
Manager at Google

NETWORK SECURITY

US \$65.99 CAN \$82.99

ISBN: 978-1-492-09659-7



Praise for *Zero Trust Networks*, 2nd edition

Zero trust is not just a strategy; it is a mindset that challenges assumptions, scrutinizes every interaction, and guards our digital systems against unseen foes. This book offers practical guidance for chief technology officers, engineers, and information technology professionals embarking on their zero trust journey.

—Ann Johnson, *Corporate Vice President, Microsoft Security*

This book packages essential concepts of zero trust security in an easy to understand language. A definitive read for beginners and professionals alike.

—Karan Dwivedi, *Security Engineering Manager at Google*

This book does an excellent job of synthesizing the zero-trust security model. It explains the key pillars of zero trust security while also covering the zero trust frameworks developed by NIST, DoD, CISA, and other organizations, making it a valuable resource for anyone seeking to understand how to implement the zero-trust security model.

—Andrew Cameron, *Automotive Industry Technical Fellow in Identity*

We may not realize this, but our lives depend on computers. When you are in an airplane, or in a hospital, or in a train, or even turning a light bulb on at home, it's all computers. A breach can cause pandemonium, and securing this infrastructure is paramount. As such, zero trust networks provide you with the fundamentals and mindset you need to understand to secure your investments. This book is a great resource for developers, infrastructure engineers, and managers alike, as it thoroughly explains the whys and hows of zero trust.

—Sahil Malik, *Security Engineer, IT Industry*

With the rapid adoption of cloud networks, bring-your-own-device, and work-from-home policies, implementing zero trust security in today's enterprise networks is an absolute must. It's a lot more complicated than it sounds. But Razi Rais and Christina

Morillo make all of the technicalities understandable for readers with general IT backgrounds. Their book is a must read for all people who administrate computer networks for business.

—*Kim Crawley, cybersecurity researcher and author of
Hacker Culture: A to Z and The Pentester Blueprint*

2ND EDITION

Zero Trust Networks

Building Secure Systems in Untrusted Networks

*Razi Rais, Christina Morillo,
Evan Gilman, and Doug Barth*

Beijing • Boston • Farnham • Sebastopol • Tokyo

O'REILLY®

Zero Trust Networks

by Razi Rais, Christina Morillo, Evan Gilman, and Doug Barth

Copyright © 2024 Christina Morillo and Razi Rais. All rights reserved.

Printed in the United States of America.

Published by O'Reilly Media, Inc., 1005 Gravenstein Highway North, Sebastopol, CA 95472.

O'Reilly books may be purchased for educational, business, or sales promotional use. Online editions are also available for most titles (<https://oreilly.com>). For more information, contact our corporate/institutional sales department: 800-998-9938 or corporate@oreilly.com.

Acquisitions Editor: Simina Calin

Development Editor: Michele Cronin

Production Editor: Ashley Stussy

Copyeditor: Liz Wheeler

Proofreader: Sonia Saruba

Indexer: WordCo Indexing Services, Inc.

Interior Designer: David Futato

Cover Designer: Karen Montgomery

Illustrator: Kate Dullea

June 2017: First Edition

March 2024: Second Edition

Revision History for the First Edition

2024-02-23: First Release

See <https://oreilly.com/catalog/errata.csp?isbn=9781492096597> for release details.

The O'Reilly logo is a registered trademark of O'Reilly Media, Inc. *Zero Trust Networks*, the cover image, and related trade dress are trademarks of O'Reilly Media, Inc.

The views expressed in this work are those of the authors and do not represent the publisher's views. While the publisher and the authors have used good faith efforts to ensure that the information and instructions contained in this work are accurate, the publisher and the authors disclaim all responsibility for errors or omissions, including without limitation responsibility for damages resulting from the use of or reliance on this work. Use of the information and instructions contained in this work is at your own risk. If any code samples or other technology this work contains or describes is subject to open source licenses or the intellectual property rights of others, it is your responsibility to ensure that your use thereof complies with such licenses and/or rights.

978-1-492-09659-7

[LSI]

Table of Contents

Preface.....	xiii
1. Zero Trust Fundamentals.....	1
What Is a Zero Trust Network?	2
Introducing the Zero Trust Control Plane	4
Evolution of the Perimeter Model	5
Managing the Global IP Address Space	5
Birth of Private IP Address Space	7
Private Networks Connect to Public Networks	7
Birth of NAT	8
The Contemporary Perimeter Model	9
Evolution of the Threat Landscape	9
Perimeter Shortcomings	12
Where the Trust Lies	15
Automation as an Enabler	16
Perimeter Versus Zero Trust	16
Applied in the Cloud	18
Role of Zero Trust in National Cybersecurity	19
Summary	20
2. Managing Trust.....	23
Threat Models	24
Common Threat Models	25
Zero Trust's Threat Model	27
Strong Authentication	28
Authenticating Trust	30
What Is a Certificate Authority?	31
Importance of PKI in Zero Trust	31

Private Versus Public PKI	32
Public PKI Is Better than None	32
Least Privilege	33
Dynamic Trust	35
Trust Score	37
Challenges with Trust Scores	38
Control Plane Versus Data Plane	39
Summary	41
3. Context-Aware Agents.....	43
What Is an Agent?	44
Agent Volatility	44
What's in an Agent?	45
How Is an Agent Used?	46
Agents Are Not for Authentication	47
How to Expose an Agent?	48
Rigidity and Fluidity, at the Same Time	49
Standardization Desirable	49
In the Meantime?	51
Summary	52
4. Making Authorization Decisions.....	55
Authorization Architecture	55
Enforcement	57
Policy Engine	58
Policy Storage	59
What Makes Good Policy?	59
Who Defines Policy?	63
Policy Reviews	63
Trust Engine	64
What Entities Are Scored?	65
Exposing Scores Considered Risky	67
Data Stores	67
Scenario Walkthrough	69
Summary	73
5. Trusting Devices.....	75
Bootstrapping Trust	75
Generating and Securing Identity	76
Identity Security in Static and Dynamic Systems	77
Authenticating Devices with the Control Plane	80

X.509	80
TPMs	84
TPMs for Device Authentication	87
HSM and TPM Attack Vectors	88
Hardware-Based Zero Trust Supplicant?	89
Inventory Management	90
Knowing What to Expect	91
Secure Introduction	92
Renewing and Measuring Device Trust	93
Local Measurement	94
Remote Measurement	95
Unified Endpoint Management (UEM)	96
Software Configuration Management	97
CM-Based Inventory	98
Searchable Inventory	98
Secure Source of Truth	99
Using Device Data for User Authorization	99
Trust Signals	100
Time Since Image	100
Historical Access	101
Location	101
Network Communication Patterns	102
Machine Learning	102
Scenario Walkthrough	102
Use Case: Bob Wants to Send a Document for Printing	106
Request Analysis	106
Use Case: Bob Wants to Delete an Email	107
Request Analysis	107
Summary	109
6. Trusting Identities.	111
Identity Authority	111
Bootstrapping Identity in a Private System	113
Government-Issued Identification	113
Nothing Beats Meatspace	114
Expectations and Stars	114
Storing Identity	115
User Directories	115
Directory Maintenance	116
When to Authenticate Identity	116
Authenticating for Trust	117

Trust as the Authentication Driver	117
The Use of Multiple Channels	118
Caching Identity and Trust	118
How to Authenticate Identity	119
Something You Know: Passwords	120
Something You Have: TOTP	121
Something You Have: Certificates	121
Something You Have: Security Tokens	122
Something You Are: Biometrics	123
Behavioral Patterns	123
Out-of-Band Authentication	124
Single Sign-On	124
Workload Identities	126
Moving Toward a Local Auth Solution	127
Authenticating and Authorizing a Group	128
Shamir's Secret Sharing	128
Red October	129
See Something, Say Something	129
Trust Signals	130
Scenario Walkthrough	131
Use Case: Bob Wants to View a Sensitive Financial Report	131
Request Analysis	133
Summary	135
7. Trusting Applications.....	137
Understanding the Application Pipeline	138
Trusting Source Code	140
Securing the Repository	141
Authentic Code and the Audit Trail	141
Code Reviews	143
Trusting Builds	143
Software Bill of Materials (SBOM): The Risk	144
Trusted Input, Trusted Output	145
Reproducible Builds	146
Decoupling Release and Artifact Versions	146
Trusting Distribution	147
Promoting an Artifact	147
Distribution Security	148
Integrity and Authenticity	148
Trusting a Distribution Network	150
Humans in the Loop	151

Trusting an Instance	152
Upgrade-Only Policy	152
Authorized Instances	153
Runtime Security	155
Secure Coding Practices	155
Isolation	156
Active Monitoring	157
Secure Software Development Lifecycle (SDLC)	159
Requirements and Design	160
Coding and Implementation	160
Static and Dynamic Code Analysis	160
Peer Reviews and Code Audits	160
Quality Assurance and Testing	160
Deployment and Maintenance	161
Continuous Improvement	161
Protecting Application and Data Privacy	161
When You Host Applications in a Public Cloud, How Can You Trust It?	161
Confidential Computing	162
Understanding Hardware-Based Root-of-Trust (RoT)	162
Role of Attestation	163
Scenario Walkthrough	163
Use Case: Bob Sends Highly Sensitive Data to Financial Application for Computation	163
Request Analysis	165
Summary	166
8. Trusting the Traffic	169
Encryption Versus Authentication	169
Authenticity Without Encryption?	170
Bootstrapping Trust: The First Packet	171
FireWall KNoCK OPerator (fwknop)	173
Short-Lived Exceptions	173
SPA Payload	173
Payload Encryption	174
HMAC	174
Where Should Zero Trust Be in the Network Model?	174
Client and Server Split	176
Network Support Issues	176
Device Support Issues	177
Application Support Issues	177
A Pragmatic Approach	178

Microsoft Server Isolation	178
The Protocols	179
IKE and IPsec	179
Mutually Authenticated TLS (mTLS)	180
Trusting Cloud Traffic: Challenges and Considerations	184
Cloud Access Security Brokers (CASBs) and Identity Federation	186
Filtering	187
Host Filtering	188
Bookended Filtering	190
Intermediary Filtering	192
Scenario Walkthrough	194
Use Case: Bob Requests Access to an Email Service Over an Anonymous Proxy Network	196
Request Analysis	196
Summary	197
9. Realizing a Zero Trust Network.....	199
The First Steps Toward a Zero Trust Network: Understanding Your Current Network	199
Choosing Scope	200
Assessment and Planning	200
Requirements: What Is Actually Required?	201
All Network Flows MUST Undergo Authentication Before Processing	202
Building a System Diagram	206
Understanding Your Flows	207
Micro-Segmentation	210
Software-Defined Perimeter	211
Controller-Less Architecture	211
“Cheating” with Configuration Management	211
Implementation Phase: Application Authentication and Authorization	212
Authenticating Load Balancers and Proxies	213
Relationship-Oriented Policy	214
Policy Distribution	214
Defining and Implementing Security Policies	215
Zero Trust Proxies	216
Client-Side Versus Server-Side Migrations	218
Endpoint Security	219
Case Studies	220
Case Study: Google BeyondCorp	220
The Major Components of BeyondCorp	222
Leveraging and Extending the GFE	225

Challenges with Multiplatform Authentication	227
Migrating to BeyondCorp	227
Lessons Learned	230
Conclusion	232
Case Study: PagerDuty's Cloud-Agnostic Network	232
Configuration Management as an Automation Platform	233
Dynamically Calculated Local Firewalls	234
Distributed Traffic Encryption	235
Decentralized User Management	236
Rollout	236
Value of a Provider-Agnostic System	238
Summary	238
10. The Adversarial View.....	239
Potential Pitfalls and Dangers	239
Attack Vectors	240
Identity and Access	241
Credential Theft	241
Privilege Escalation and Lateral Movement	242
Infrastructure and Networks	244
Control Plane Security	244
Endpoint Enumeration	246
Untrusted Computing Platform	247
Distributed Denial of Service (DDoS) Attacks	247
Man-in-the-Middle (MitM) Attacks	248
Invalidation	249
Phishing	250
Physical Coercion	250
Role of Cyber Insurance	251
Summary	252
11. Zero Trust Architecture Standards, Frameworks, and Guidelines.....	253
Governments	254
United States	255
United Kingdom	276
European Union	277
Private and Public Organizations	277
Cloud Security Alliance (CSA)	277
The Open Group	278
Gartner	278
Forrester	279

International Organization for Standardization (ISO)	280
Commercial Vendors	281
Summary	282
12. Challenges and the Road Ahead.....	283
Challenges	283
Mindset Shift	283
Shadow IT	284
Siloed Organizations	285
Lack of Cohesive Zero Trust Products	285
Scalability and Performance	286
Key Takeaways	286
Technological Advancements	287
Quantum Computing	287
Artificial Intelligence	289
Privacy-Enhancing Technologies	291
Summary	292
Appendix. A Brief Introduction to Network Models.....	295
Index.....	299

Preface

Thank you for choosing to read *Zero Trust Networks, 2E*! Building trusted systems in hostile networks has been a passion of ours for many years. In building and designing such systems, we have found frustration in the pace of progress toward solving some of the more fundamental security problems plaguing our industry. We'd very much like to see the industry move more aggressively toward building systems that strive to solve these problems.

To that end, we propose that the world take a new stance toward building and maintaining secure computer networks. Rather than being something that is layered on top, only considered after some value has been built, security must be fundamentally infused with the operation of the system itself. It must be ever-present, enabling operation rather than restricting it. As such, this book sets forth a collection of design patterns and considerations which, when heeded, can produce systems that are resilient to the vast majority of modern-day attack vectors.

This collection, when taken as a whole, is known as the zero trust model. In this model, nothing is taken for granted, and every single access request—whether it's made by a client in a coffee shop or a server in the datacenter—is rigorously checked and proven to be authorized. Adopting this model practically eliminates lateral movement, VPN headaches, and centralized firewall management overhead. It is a very different model; one that we believe represents the future of network and infrastructure security design.

In the second edition, we broaden the scope to include recent developments in zero trust. We have added two entirely new chapters and additional real-world scenario walkthroughs to the current chapters. The chapter on zero trust architectural standards, frameworks, and guidelines will help you better grasp the zero trust perspective from leading organizations, such as NIST, CISA, DoD, and others. Since zero trust initiatives are not easy, we added a chapter dedicated to discussing challenges and practical advice to deal with them. This chapter finishes with an examination of more recent technical advancements, including artificial intelligence, quantum computing,

and privacy-preserving technologies, all of which are highly relevant to zero trust and cybersecurity in general.

Who Should Read This Book

Have you found the overhead of centralized firewalls to be restrictive? Perhaps you've even found their operation to be ineffective. Have you struggled with VPN headaches, TLS configuration across a myriad of applications and languages, or compliance and auditing hardships? These problems represent a small subset of those addressed by the zero trust model. If you find yourself thinking that there just has to be a better way, then you're in luck—this book is for you.

Network engineers, security engineers, CTOs, and everyone in between can benefit from zero trust learnings. Even without a specialized skill set, many of the principles included in this book can be clearly understood, helping leaders make decisions that implement a zero trust model, improving their overall security posture incrementally.

Additionally, readers with experience using configuration management systems will see the opportunity to use those same ideas to build a more secure and operable networked system—one in which resources are secure by default. They will be interested in how automation systems can enable a new network design that is able to apply fine-grained security controls more easily. Finally, this book explores a mature zero trust design, enabling those who have already incorporated the basic philosophies to further the robustness of their security systems.

Why We Wrote This Book

We started speaking about our approach to system and network design at industry conferences in 2014. At the time, we were using configuration management systems to rigorously define the system state, applying changes programmatically as a reaction to topological changes. As a result of leveraging automation tools for this purpose, we naturally found ourselves programmatically calculating the network enforcement details instead of managing the configuration by hand. We found that using automation to capture the system design in this way allowed us to deploy and manage security features, including access control and encryption, much more easily than in systems past. Even better, doing so allowed us to place much less trust in the network than other systems might normally do, which is a key security consideration when operating in and across public clouds.

While writing this book, we spoke to individuals from dozens of companies to understand their perspective on network security designs. We found that many of those companies were reducing the trust of their internal networks. While each organization took a slightly different approach in their own system, it was clear that

they were all working under the same threat model and were, as a result, building solutions that shared many properties.

Our goal with this book isn't to present one or two particular solutions to building these types of systems, but rather to define a system model that places no trust in its communication network. Therefore, this book won't be focused on using specific vendor software or implementations, but rather it will explore the concepts and philosophies that are used to build a zero trust network. We hope you will find it useful to have a clear mental model for how to construct this type of system when building your own system or, even better, reusable solutions for the problems described herein.

Navigating This Book

This book is organized as follows:

- Chapters 1 and 2 discuss the fundamental concepts at play in a zero trust security model.
- Chapters 3 and 4 explore the new concepts typically seen in mature zero trust networks: context-aware network agents and trust engines.
- Chapters 5 through 8 detail how trust is established among the various actors in a network, with focus on devices, identities, applications, and network traffic. Most of this content is focused on existing technology that could be useful in a traditional network security model. The scenario walkthroughs at the end of each chapter will help you understand how the core principles of zero trust are used in a real-world setting.
- Chapter 9 brings all this content together to discuss how you could begin building your own zero trust network and includes two case studies.
- Chapter 10 looks at the zero trust security model from an adversarial view. It explores potential weaknesses, discussing which are well mitigated and which are not.
- Chapter 11 explores zero trust architectures, standards, and frameworks from NIST, CISA, DoD, and others. The goal is to help you understand the zero trust security model from the perspective of leading organizations in the industry.
- Chapter 12 outlines various functional and technical obstacles that organizations experience when implementing zero initiatives. It also provides high-level considerations that may assist you in effectively dealing with these challenges. Additionally, it examines the impact of artificial intelligence (AI), quantum computing, and privacy-enhancing technologies on zero trust security models, which are extremely important advancements to understand. The potential impact of AI, quantum computation, and privacy-enhancing technologies on zero trust

security model is also examined. Comprehending these advancements is of the utmost importance, given their pivotal role in cybersecurity strategy.

Conventions Used in This Book

The following typographical conventions are used in this book:

Italic

Indicates new terms, URLs, email addresses, filenames, and file extensions.

Constant width

Used for program listings, as well as within paragraphs to refer to program elements such as variable or function names, databases, data types, environment variables, statements, and keywords.



This element signifies a general note.



This element indicates a warning or caution.

O'Reilly Online Learning



For more than 40 years, *O'Reilly Media* has provided technology and business training, knowledge, and insight to help companies succeed.

Our unique network of experts and innovators share their knowledge and expertise through books, articles, and our online learning platform. O'Reilly's online learning platform gives you on-demand access to live training courses, in-depth learning paths, interactive coding environments, and a vast collection of text and video from O'Reilly and 200+ other publishers. For more information, visit <https://oreilly.com>.

How to Contact Us

Please address comments and questions concerning this book to the publisher:

O'Reilly Media, Inc.
1005 Gravenstein Highway North
Sebastopol, CA 95472
800-889-8969 (in the United States or Canada)
707-827-7019 (international or local)
707-829-0104 (fax)
support@oreilly.com
<https://www.oreilly.com/about/contact.html>

We have a web page for this book, where we list errata, examples, and any additional information. You can access this page at *<https://oreil.ly/zero-trust-networks-2e>*.

For news and information about our books and courses, visit *<https://oreilly.com>*.

Find us on LinkedIn: *<https://linkedin.com/company/oreilly-media>*

Follow us on Twitter: *<https://twitter.com/oreillymedia>*

Watch us on YouTube: *<https://youtube.com/oreillymedia>*

Acknowledgments from the First Edition

We would like to thank our editor, Courtney Allen, for her help and guidance during the writing process. Thanks also to Virginia Wilson, Nan Barber, and Maureen Spencer for their help during the review.

We had the opportunity to meet with many people during the writing of this content, and we appreciate their willingness to speak with us and provide intros to other folks working in this space. Thanks to Rory Ward, Junaid Islam, Stephen Woodrow, John Kindervag, Arup Chakrabarti, Julia Evans, Ed Bellis, Andrew Dunham, Bryan Berg, Richo Healey, Cedric Staub, Jesse Endahl, Andrew Miklas, Peter Smith, Dimitri Stiliadis, Jason Chan, and David Cheney.

A special thanks to Betsy Beyer for writing the Google BeyondCorp case study included in the book. We really appreciate your willingness to work on getting that content included. Thanks!

Thanks to our technical reviewers, Ryan Huber, Kevin Babcock, and Pat Cable. We found your comments invaluable and appreciate the time you took to read through the initial drafts.

Doug would like to thank his wife, Erin, and daughters, Persephone and Daphne, for being so very understanding of the time it took to write this book.

Evan thanks his partner, Kristen, for all of her support through the writing of this book. He would also like to thank Kareem Ali and Kenrick Thomas—without them, none of this would have been possible.

Acknowledgments from the Second Edition

We are especially grateful to Michele Cronin, our development editor, for her assistance and direction throughout the process. Thanks also to Simina Calin, our acquisitions editor, for helping us in establishing a successful path for this book.

Our heartfelt thanks goes out to our technical reviewers, including Kim Crawley, Steve Winterfeld, and Karan Dwivedi, whose extensive feedback and recommendations have enhanced every facet of this book. Many thanks!

Razi would like to thank his wonderful wife, Javeria, as well as his mother and sister, Zahida and Khaizran, for their unwavering support throughout the writing of this book.

Christina would like to thank her husband and children for their steadfast support and patience during the book-writing journey.

Zero Trust Fundamentals

In an age when network surveillance is ubiquitous, we find it difficult to trust anyone, and defining what trust is itself is equally difficult. Can we trust that our internet traffic will be safe from eavesdropping? Certainly not! What about that provider you leased your fiber from? Or that contracted technician who was in your datacenter yesterday working on the cabling?

Whistleblowers like Edward Snowden and Mark Klein have revealed the tenacity of government-backed spy rings. The world was shocked at the revelation that they had managed to get inside the datacenters of large organizations. But why? Isn't it exactly what you would do in their position? Especially if you knew that traffic there would not be encrypted?

The assumption that systems and traffic within a datacenter can be trusted is flawed. Modern networks and usage patterns no longer echo those that made perimeter defense make sense many years ago. As a result, moving freely within a "secure" infrastructure frequently has a low barrier to entry once a single host or link there has been compromised.

You may think that the idea of using a cyberattack as a weapon to disrupt critical infrastructure like a nuclear plant or a power grid is far-fetched, but cyberattacks on the **Colonial Pipeline** in the United States and the **Kudankulam Nuclear Power Plant in India** serve as a stark reminder that critical infrastructure will continue to be a high-value target for attackers. So, what was common between the two attacks?

Well, in both cases, security was abysmal. Attackers took advantage of the fact that the VPN (virtual private network) connection to the Colonial Pipeline network was possible using a plain-text password without any multifactor authentication (MFA) in place. In the other example, malware was discovered on an Indian nuclear power plant employee's computer that was connected to the administrative network's internet servers. Once the attackers gained access, they were able to roam within the network due to the “trust” that comes with being inside the network.

Zero trust aims to solve the inherent problems in placing our trust in the network. Instead, it is possible to secure network communication and access so effectively that the physical security of the transport layer can be reasonably disregarded. It goes without saying that this is a lofty goal. The good news is that we've got pretty powerful cryptographic algorithms these days, and given the right automation systems, this vision is actually attainable.

What Is a Zero Trust Network?

A zero trust network is built upon five fundamental assertions:

- The network is always assumed to be hostile.
- External and internal threats exist on the network at all times.
- Network locality alone is not sufficient for deciding trust in a network.
- Every device, user, and network flow is authenticated and authorized.
- Policies must be dynamic and calculated from as many sources of data as possible.

Traditional network security architecture breaks different networks (or pieces of a single network) into zones, contained by one or more firewalls. Each zone is granted some level of trust, which determines the network resources it is permitted to reach. This model provides very strong defense-in-depth. For example, resources deemed more risky, such as web servers that face the public internet, are placed in an exclusion zone (often termed a “DMZ”), where traffic can be tightly monitored and controlled. Such an approach gives rise to an architecture that is similar to some you might have seen before, such as the one shown in [Figure 1-1](#).

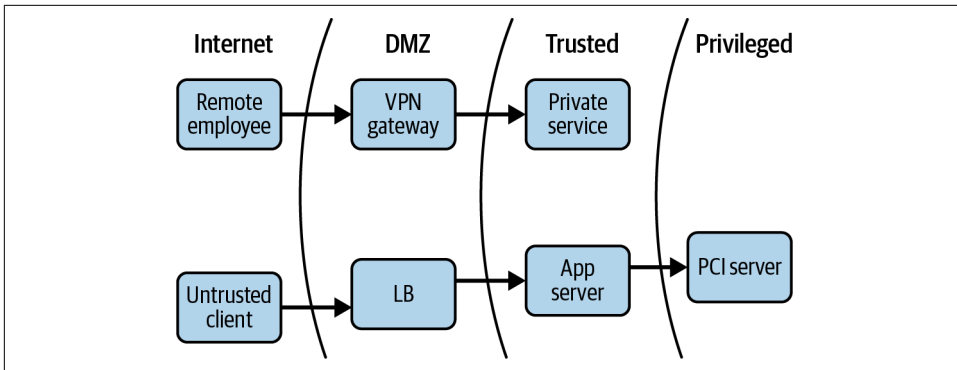


Figure 1-1. Traditional network security architecture

The zero trust model turns this diagram inside out. Placing stopgaps in the network is a solid step forward from the designs of yesteryear, but it is significantly lacking in the modern cyberattack landscape. There are many disadvantages:

- Lack of intra-zone traffic inspection
- Lack of flexibility in host placement (both physical and logical)
- Single points of failure

It should be noted that, should network locality requirements be removed, the need for VPNs is also removed. A virtual private network (VPN) allows a user to authenticate in order to receive an IP address on a remote network. The traffic is then tunneled from the device to the remote network, where it is decapsulated and routed. It's the greatest backdoor that no one ever suspected. If we instead declare that network location has no value, VPN is suddenly rendered obsolete, along with several other modern network constructs. Of course, this mandate necessitates pushing enforcement as far toward the network edge as possible, but at the same time it relieves the core from such responsibility. Additionally, stateful firewalls exist in all major operating systems, and advances in switching and routing have opened an opportunity to install advanced capabilities at the edge. All of these gains come together to form one conclusion: the time is right for a paradigm shift. By leveraging distributed policy enforcement and applying zero trust principles, we can produce a design similar to the one shown in [Figure 1-2](#).

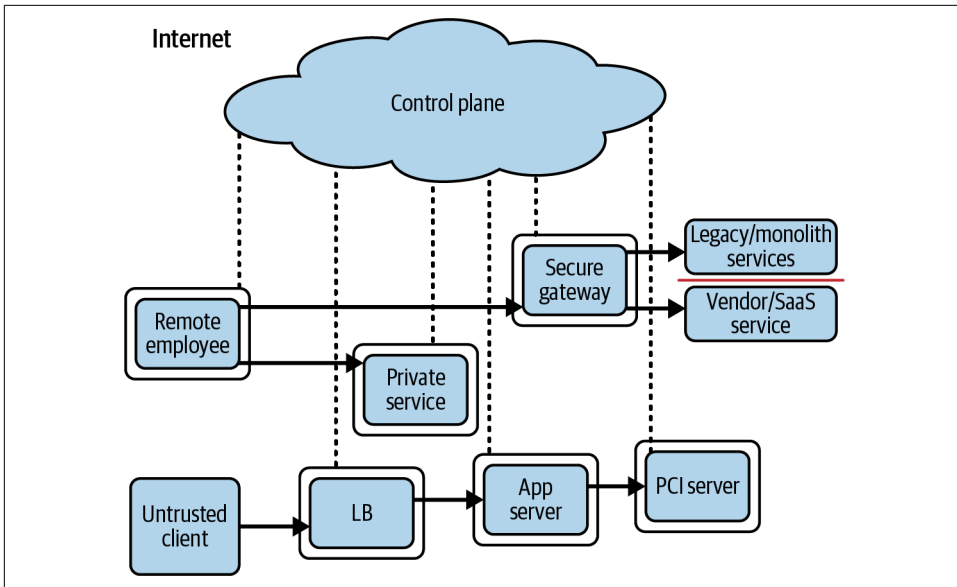


Figure 1-2. Zero trust architecture

Introducing the Zero Trust Control Plane

The supporting system is known as the control plane, while most everything else is referred to as the data plane, which the control plane coordinates and configures. Requests for access to protected resources are first made through the control plane, where both the device and user must be authenticated and authorized. Fine-grained policy can be applied at this layer, perhaps based on role in the organization, time of day, geo-location, or type of device. Access to more secure resources can additionally mandate stronger authentication.

Once the control plane has decided that the request will be allowed, it dynamically configures the data plane to accept traffic from that client (and that client only). In addition, it can coordinate the details of an encrypted tunnel between the requestor and the resource. This can include temporary one-time-use credentials, keys, and ephemeral port numbers.

It should be noted that the control plane decision to allow a request is time-bound rather than permanent. This means that if and when the factors that led the control plane decision to allow the request in the first place have changed, it may coordinate with the data plane to revoke the requested access to the resource.

While some compromises can be made on the strength of these measures, the basic idea is that an authoritative source, or trusted third party, is granted the ability to authenticate, authorize, and coordinate access in real time, based on a variety of inputs. We'll discuss the control and data planes more in [Chapter 2](#).

Evolution of the Perimeter Model

The traditional architecture described in this book is often referred to as the perimeter model, after the castle-wall approach used in physical security. This approach protects sensitive items by building lines of defenses that an intruder must penetrate before gaining access. Unfortunately, this approach is fundamentally flawed in the context of computer networks and no longer suffices. To fully understand the failure, it is useful to recall how the current model was arrived at.

Managing the Global IP Address Space

The journey that led to the perimeter model began with address assignment. Networks were being connected at an ever-increasing rate during the days of the early internet. If a network wasn't being connected to the internet (remember, the internet wasn't ubiquitous at the time), it was being connected to another business unit, another company, or perhaps a research network. Of course, IP addresses must be unique in any given IP network, and if the network operators were unlucky enough to have overlapping ranges, they would have a lot of work to do in changing them all. If the network you are connecting to happens to be the internet, then your addresses must be globally unique. So clearly some coordination is required here.

The [Internet Assigned Numbers Authority \(IANA\)](#), formally established in 1998, is the body that today provides that coordination. Prior to the establishment of the IANA, this responsibility was handled by Jon Postel, who created the internet map shown in [Figure 1-3](#). He was the authoritative source for IP address ownership records, and if you wanted to guarantee that your IP addresses were globally unique, you would register with him. At this time, everybody was encouraged to register for IP address space, even if the network being registered was not going to be connected to the internet. The assumption was that even if a network was not connected now, it would probably be connected to another network at some point.

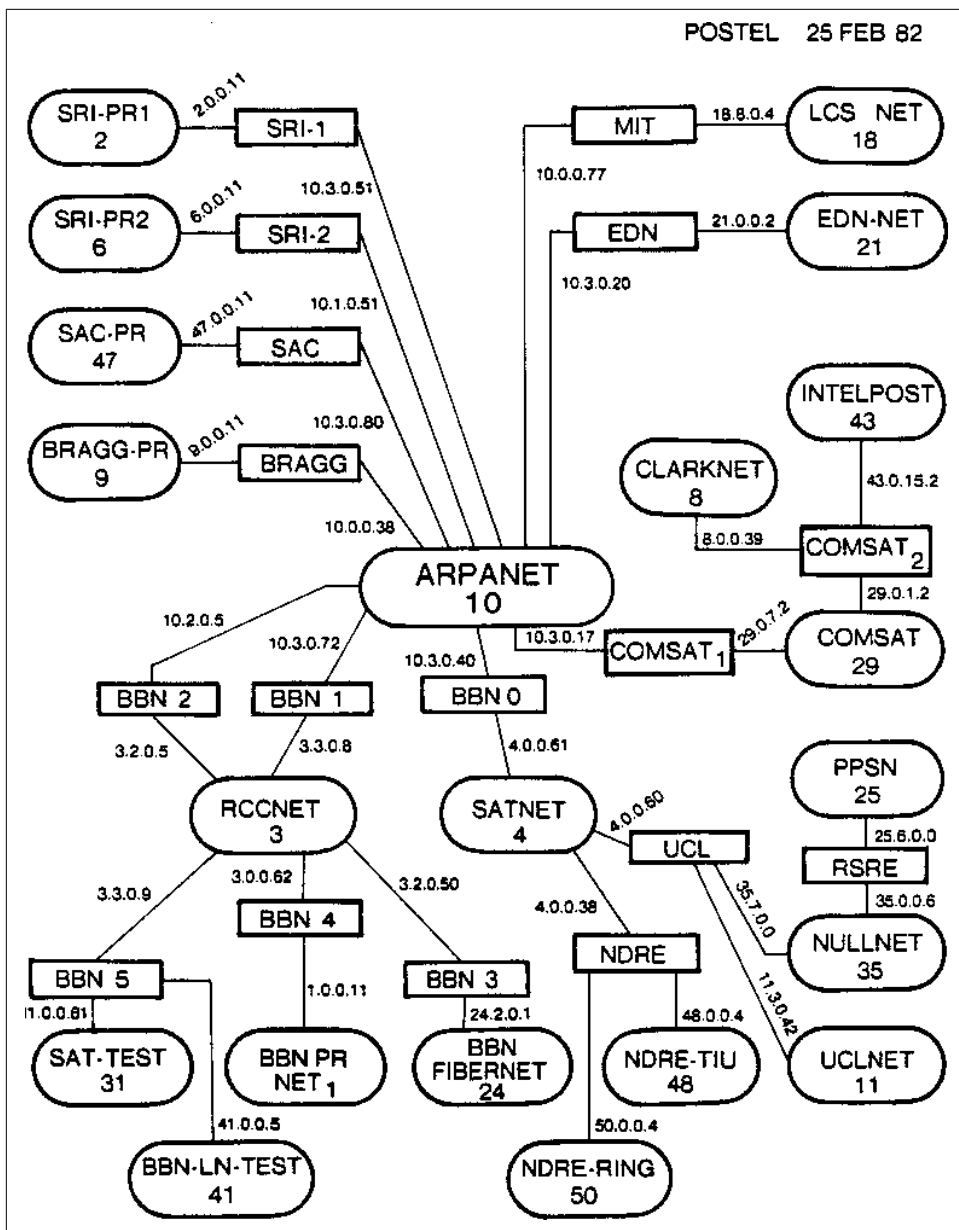


Figure 1-3. A map of the early internet created by Jon Postel, dated February 1982

Birth of Private IP Address Space

As IP adoption grew through the late 1980s and early 1990s, frivolous use of address space became a serious concern. Numerous cases of truly isolated networks with large IP address space requirements began to emerge. Networks connecting ATMs and arrival/departure displays at large airports were touted as prime examples. These networks were considered truly isolated for various reasons. Some devices might be isolated to meet security or privacy requirements (e.g., networks meant for ATMs). Some might be isolated because the scope of their function was so limited that having broader network access was seen as exceedingly unlikely (e.g., airport arrival and departure displays). [RFC 1597](#), Address Allocation for Private Internets, was introduced to address this wasted public address space issue.

In March of 1994, RFC 1597 announced that three IP network ranges had been reserved with IANA for general use in private networks: 10.0.0.0/8, 172.16.0.0/12, and 192.168.0.0/16. This had the effect of slowing address depletion by ensuring that the address space of large private networks never grew beyond those allocations. It also enabled network operators to use nonglobally unique addresses where and when they saw fit. It had another interesting effect, which lingers with us today: networks using private addresses were more secure, because they were fundamentally incapable of joining other networks, particularly the internet.

At the time, very few organizations (relatively speaking) had an internet connection or presence, and as such, internal networks were frequently numbered with the reserved ranges. Additionally, security measures were weak to nonexistent because these networks were typically confined by the walls of a single organization.

Private Networks Connect to Public Networks

The number of interesting things on the internet grew fairly quickly, and soon most organizations wanted at least some sort of presence. Email was one of the earliest examples of this. People wanted to be able to send and receive email, but that meant they needed a publicly accessible mail server, which of course meant that they needed to connect to the internet somehow. With established private networks, it was often the case that this mail server would be the only server with an internet connection. It would have one network interface facing the internet, and one facing the internal network. With that, systems and people on the internal private network got the ability to send and receive internet email via their connected mail server.

It was quickly realized that these servers had opened up a physical internet path into their otherwise secure and private network. If one was compromised, an attacker might be able to work their way into the private network, since hosts there can communicate with it. This realization prompted strict scrutiny of these hosts and their network connections. Network operators placed firewalls on both sides of them

to restrict communication and thwart potential attackers attempting to access internal systems from the internet, as shown in [Figure 1-4](#). With this step, the perimeter model was born. The internal network became the “secure” network, and the tightly controlled pocket that the external hosts lay in became the DMZ, or the demilitarized zone.

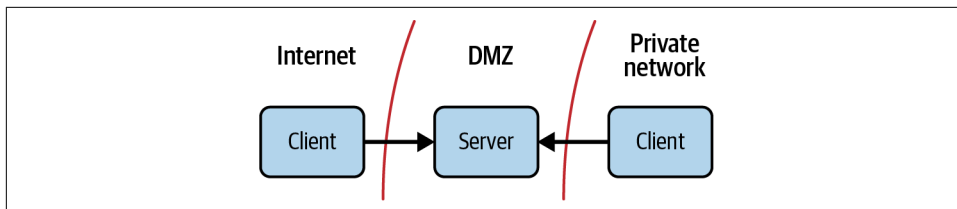


Figure 1-4. Both internet and private resources can access hosts in the DMZ; private resources, however, cannot reach beyond the DMZ, and thus do not gain direct internet access

Birth of NAT

The number of internet resources being accessed from internal networks was growing rapidly, and it quickly became easier to grant general internet access to internal resources than it was to maintain intermediary hosts for every application desired. NAT, or network address translation, solved that problem nicely.

[RFC 1631](#), The IP Network Address Translator, defines a standard for a network device that is capable of performing IP address translation at organizational boundaries. By maintaining a table that maps public IPs and ports to private ones, it enabled devices on private networks to access arbitrary internet resources. This lightweight mapping is application agnostic, which meant that network operators no longer needed to support internet connectivity for particular applications; they needed only to support internet connectivity in general.

These NAT devices had an interesting property: because the IP mapping was many-to-one, it was not possible for incoming connections from the internet to access internal private IPs without specifically configuring the NAT to handle this special case. In this way, the devices exhibited the same properties as a stateful firewall. Actual firewalls began integrating NAT features almost instantaneously, and the two became a single function, largely indistinguishable. Supporting both network compatibility and tight security controls meant that eventually you could find one of these devices at practically every organizational boundary, as shown in [Figure 1-5](#).

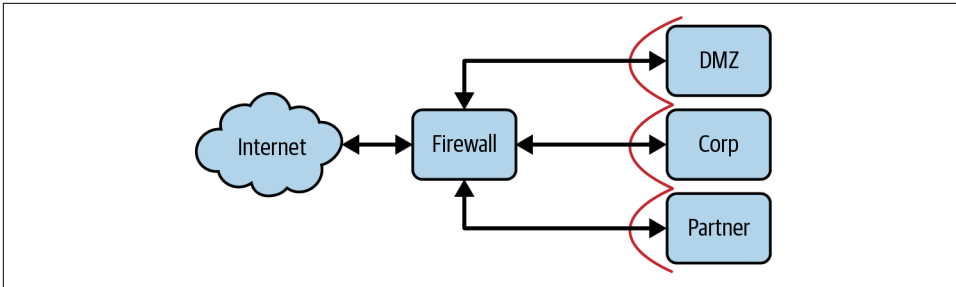


Figure 1-5. Typical (and simplified) perimeter firewall design

The Contemporary Perimeter Model

With a firewall/NAT device between the internal network and the internet, the security zones are clearly forming. There is the internal “secure” zone, the DMZ (demilitarized zone), and the untrusted zone (aka the internet). If at some point in the future, this organization needed to interconnect with another, a device would be placed on that boundary in a similar manner. The neighboring organization would likely become a new security zone, with particular rules about what kind of traffic can go from one to the other, just like the DMZ or the secure zone.

Looking back, we see the progression. We went from offline/private networks with just one or two hosts with internet access to highly interconnected networks with security devices around the perimeter. It is not hard to understand: network operators couldn’t afford to sacrifice the perfect security of their offline network because they had to open doors for various business purposes. Tight security controls at each door minimized the risk.

Evolution of the Threat Landscape

Even before the public internet, communicating with a remote computer system was highly desirable. This was commonly done over the public telephone system. Users and computer systems could dial in and, by encoding data into audible tones, gain connectivity to the remote machine. These dial-in interfaces were the most common attack vector of the day, since gaining physical access was much more difficult.

Once organizations had internet-connected hosts, attacks shifted from occurring over the telephone network to being launched over the dial-up internet. This triggered a change in most attack dynamics. Incoming calls to dial-in interfaces tied up a phone line, and were a notable occurrence when compared to a TCP connection coming from the internet. It was much easier to have a covert presence on an IP network than it was on a system that needed to be dialed into. Exploitation and brute force attempts could be carried out over long periods of time without raising too much

suspicion...though an additional and more impactful capability arose from this shift: malicious code could then listen for internet traffic.

By the late 1990s, the world's first (software) Trojan horses began to make their rounds. Typically, a user would be tricked into installing the malware, which would then open a port and wait for incoming connections. The attacker could then connect to the open port and remotely control the target machine.

It wasn't long before that people realized it would be a good idea to protect those internet-facing hosts. Hardware firewalls were the best way to do it (most operating systems had no concept of a host-based firewall at the time). They provided policy enforcement, ensuring that only whitelisted/allowed-listed "safe" traffic was allowed in from the internet. If an administrator inadvertently installed something that exposed an open port (like a Trojan horse), the firewall would physically block connections to that port until explicitly configured to allow it. Likewise, traffic to the internet-facing servers from inside the network could be controlled, ensuring that internal users could speak to them, but not vice versa. This helped prevent movement into the internal network by a potentially compromised DMZ host.

DMZ hosts were of course a prime target (due to their connectivity), though such tight controls on both inbound and outbound traffic made it hard to reach an internal network through a DMZ. An attacker would first have to compromise the firewalled server, then abuse the application in such a way that it could be used for covert communication (they need to get data out of that network, after all). Dial-in interfaces remained the lowest-hanging fruit if one was determined to gain access to an internal network.

This is where things took an interesting turn. NAT was introduced to grant internet access to clients on internal networks. Due in some part to NAT mechanics and in some part to real security concerns, there was still tight control on inbound traffic, though internal resources wishing to consume external resources might freely do so. There's an important distinction to be made when considering a network with NAT'd internet access against a network without it: the former has a relaxed (if any) outbound network policy.

This significantly transformed the network security model. Hosts on the "trusted" internal networks could then communicate directly with untrusted internet hosts, and the untrusted host was suddenly in a position to abuse the client attempting to speak with it. Even worse, malicious code could then send messages to internet hosts from within the internal network. Today, we know this as "phoning home."

Phoning home is a critical component of most modern attacks. It allows data to be exfiltrated from otherwise-protected networks; but more importantly, since TCP is bidirectional, it allows data to be injected as well. A typical attack involves several steps, as shown in [Figure 1-6](#). First, the attacker will compromise a single computer

on the internal network by exploiting the user's browser when they visit a particular page, by sending them an email with an attachment that exploits some local software, for example. The exploit carries a very small payload, just enough code to make a connection out to a remote internet host and execute the code it receives in the response. This payload is sometimes referred to as a dialer.

The dialer downloads and installs the real malware, which more often than not will attempt to make an additional connection to a remote internet host controlled by the attacker. The attacker will use this connection to send commands to the malware, exfiltrate sensitive data, or even to obtain an interactive session. This “patient zero” can act as a stepping stone, giving the attacker a host on the internal network from which to launch additional attacks.

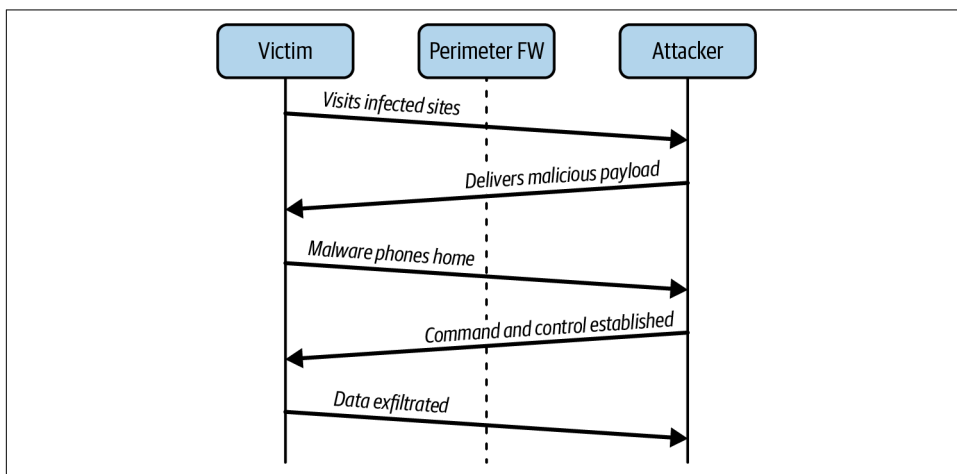


Figure 1-6. Client initiates all attack-related connections, easily traversing perimeter firewalls with relaxed outbound security



Outbound Security

Outbound network security is a very effective mitigation measure against dialer-based attacks, as the phone home can be detected and/or blocked. Oftentimes, however, the phone home is disguised as regular web traffic, possibly even to networks that are seemingly benign or “normal.” Outbound security tight enough to stop these attacks will oftentimes cripple web usability for users. This is a more realistic prospect for back-office systems.

The ability to launch attacks from hosts within an internal network is a very powerful one. These hosts almost certainly have permission to talk to other hosts in the same security zone (lateral movement) and might even have access to talk to hosts in zones more secure than their own. To this effect, by first compromising a low-security

zone on the internal network, an attacker can move through the network, eventually gaining access to the high-security zones.

Taking a step back for a moment, it can be seen that this pattern very effectively undermines the perimeter security model. The critical flaw enabling attack progression is subtle, yet clear: security policies are defined by network zones, enforced only at zone boundaries, using nothing more than the source and destination details.

Other threats have risen as the world has become more ubiquitous over the years. Companies nowadays allow their workers to use their own devices for work in addition to the devices provided by the company, thanks to the popularity of Bring Your Own Device (BYOD). Employees can be more productive as a result of this, as they work from home more than ever before. During COVID-19, we discovered the advantages of BYOD when employees were no longer able to enter the workplace for extended periods of time. However, the attack surface area has grown because patching numerous devices with the most recent security fixes is significantly more difficult than patching a single device. One type of attack, among others, is the zero-click attack, which does not even require user interaction (more about it in the note below). Attackers deliberately look for devices that haven't had their security patches updated in order to exploit vulnerabilities and obtain unauthorized access to them. In [Chapter 5](#), we'll look at the role of security patches and how to automate them to improve device trust.



Zero-Click Attack

A zero-click attack is a highly sophisticated attack that infects the user's device without the user's involvement. Zero-click attacks frequently take advantage of unpatched arbitrary code execution and buffer overflow security flaws. Because these attacks are conducted without user interaction, they can be incredibly effective. Popular apps like [WhatsApp](#) and [Apple's iMessage](#) have been reported to be vulnerable to zero-click attacks. In 2021, Google provided a comprehensive investigation of the [iMessage zero-click vulnerability](#), which describes the attack's far-reaching ramifications. Patching all devices that have access to company resources and services is critical at all times.

Perimeter Shortcomings

Even though the perimeter security model still stands as the most prevalent model by far, it is increasingly obvious that the way we rely on it is flawed. Complex (and successful) attacks against networks with perfectly good perimeter security occur every day. An attacker drops a remote access tool (or RAT) into your network through one of a myriad of methods, gains remote access, and begins moving laterally. Perimeter

firewalls have become the functional equivalent of building a wall around a city to keep out the spies.

The problem comes when architecting security zones into the network itself. Imagine the following scenario: you run a small ecommerce company. You have some employees, some internal systems (payroll, inventory, etc.), and some servers to power your website. It is natural to begin classifying the kind of access these groups might need: employees need access to internal systems, web servers need access to database servers, database servers don't need internet access but employees do, and so on. Traditional network security would codify these groups as zones and then define which zone can access what, as shown in [Figure 1-7](#). Of course, you need to actually enforce these policies; and since they are defined on a zone-by-zone basis, it makes sense to enforce them wherever one zone can route traffic into another.

As you might imagine, there are always exceptions to these generalized rules...they are, in fact, colloquially known as firewall exceptions. These exceptions are typically as tightly scoped as possible. For instance, your web developer might want SSH access to the production web servers, or your HR representative might need access to the HR software's database in order to perform audits. In these cases, an acceptable approach is to configure a firewall exception permitting traffic from that individual's IP address to the particular server(s) in question.

Now let's imagine that your archnemesis has hired a team of hackers. They want to have a peek at your inventory and sales numbers. The hackers send emails to all the employee email addresses they can find on the internet, masquerading as a discount code for a restaurant near the office. Sure enough, one of them clicks the link, allowing the attackers to install malware. The malware phones home and provides the attackers with a session on the now-compromised employee's machine. Luckily, it's only an intern, and the level of access they gain is limited.

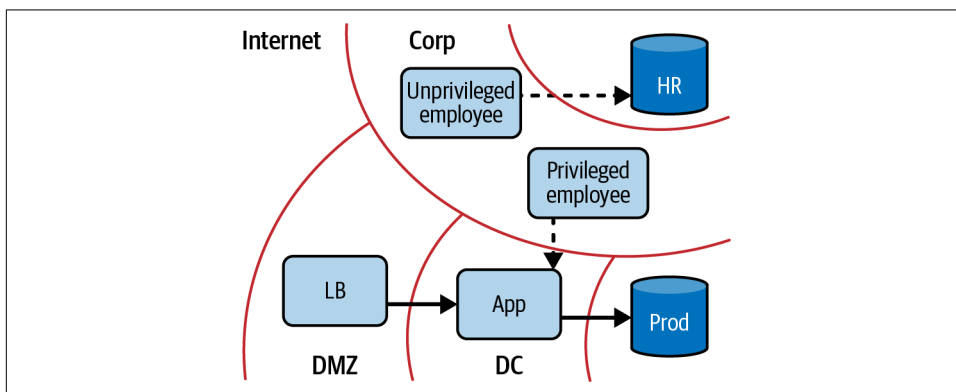


Figure 1-7. Corporate network interacting with the production network

They begin searching the network and find that the company is using file sharing software on its network. Out of all the employee computers on the network, none of them have the latest version and are vulnerable to an attack that was recently publicized.

One by one, the hackers begin searching for a computer with elevated access (this process of course can be more targeted if the attacker has advanced knowledge). Eventually they come across your web developer's machine. A keylogger they install there recovers the credentials to log in to the web server. They SSH to the server using the credentials they gathered, and using the sudo rights of the web developer, they read the database password from disk and connect to the database. They dump the contents of the database, download it, and delete all the log files. If you're lucky, you might actually discover that this breach occurred. They accomplished their mission, as shown in **Figure 1-8**.

Wait, what? As you can see, many failures at many levels led to this breach, and while you might think that this is a particularly contrived case, successful attacks just like this one are staggeringly common. The most surprising part, however, goes unnoticed all too often: what happened to all that network security? Firewalls were meticulously placed, policies and exceptions were tightly scoped and very limited, everything was done right from a network security perspective. So what gives?

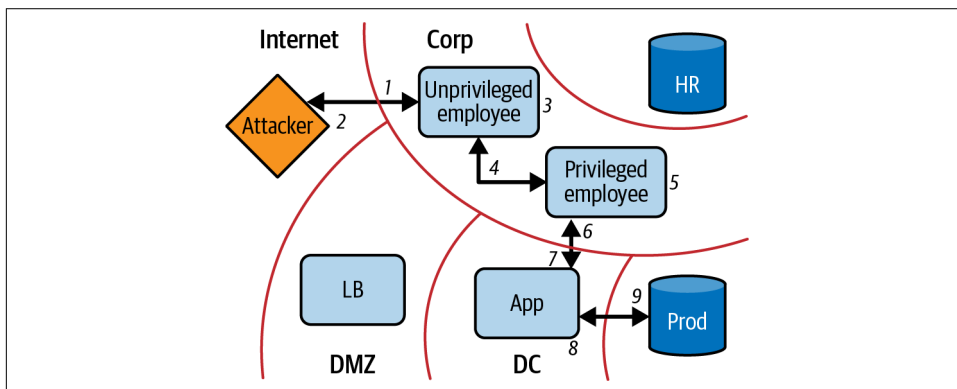


Figure 1-8. Attacker movement into corporate network, and subsequently production into network

When carefully examined, it is overwhelmingly obvious that this network security model is not enough. Bypassing perimeter security is trivial with malware that phones home, and firewalls between zones consider nothing more than source and destination when making enforcement decisions. While perimeters can still provide some value in network security, their role as the primary mechanism by which a network's security stance is defined needs to be reconsidered.